Information Assurance and Security – ACIT4630

Iman Anooshehpour
Week 2

BRITISH COLUMBIA
INSTITUTE TECHNOLOGY

BCIT™

About your Presentation

1. Select an **Interesting, Recent, Critical** Vulnerability from: NVD.NIST.GOV
2. Send me the Vulnerability Code, I'll confirm if it's good.
3. Make a Presentation about it.
4. Present it in-class.

Computing > Laptops > MacBooks

Unpatchable vulnerability discovered in Apple M1, M2 and M3 chips — what you need to know

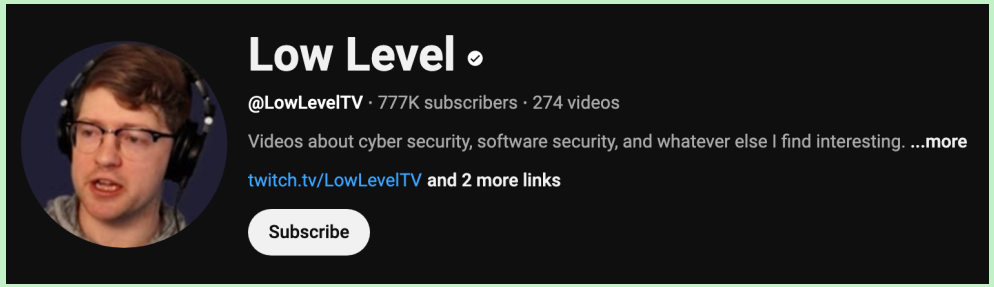
News By Anthony Spadafora published March 22, 2024

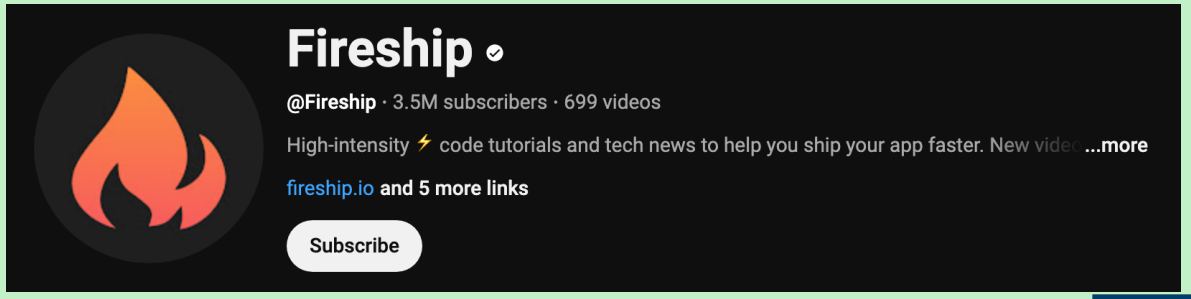
New side-channel attack breaks encryption on Apple silicon

Comments (0)

Note about your Presentation

1. Present any week. Starting next week.
2. Your presentation should be 10-15 mins excluding the Q&A
3. You will be asked questions about your presentation.
4. Max 2 presentation in a class except week 7 (Midterm Review + Presentations)





CVE (Common Vulnerabilities and Exposures)

•**Definition**: A standardized list of publicly disclosed security vulnerabilities in software/hardware.

•**Purpose**: Helps organizations track, share, and prioritize security issues.

•**Examples**:

- **CVE-2021-44228**: Log4j2 (Log4Shell) remote code execution.
- **CVE-2020-1472**: ZeroLogon vulnerability in Microsoft Netlogon.

CWE (Common Weakness Enumeration)

•**Definition**: A catalog of common software weaknesses that lead to security vulnerabilities.

•**Purpose**: Helps identify and prevent software flaws, improving security.

•**Examples**:

- **CWE-79**: Cross-Site Scripting (XSS).
- **CWE-89**: SQL Injection.
- **CWE-120**: Buffer Overflow.

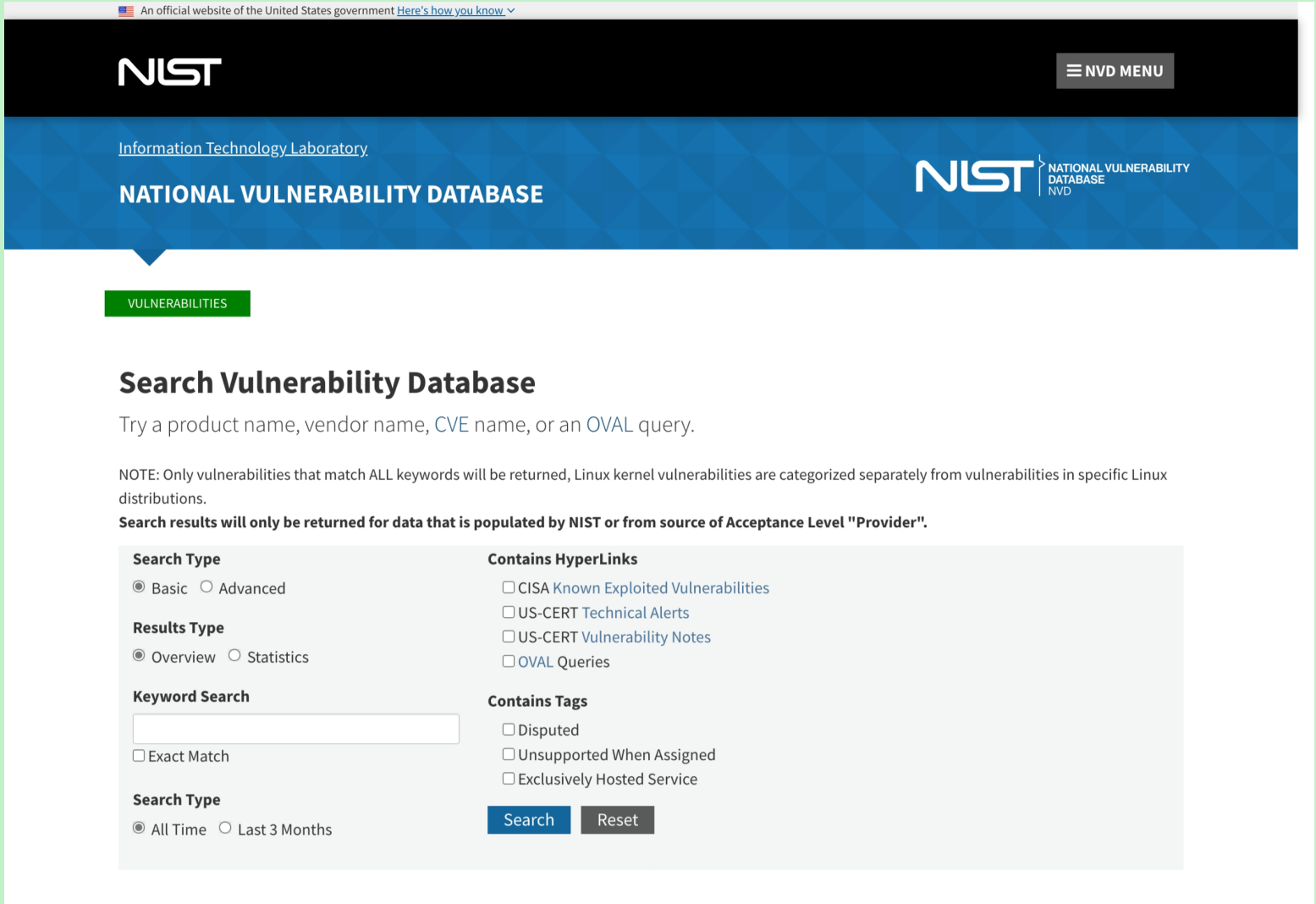
Presentation Rubric

Criteria	Description	Weight (%)
Attack Goal(s) / Objective(s)	Clearly explain the attacker's goal(s) and objective(s) behind exploiting the CVE.	15%
Attack Consequences & Compromised Security Objectives	Detail the consequences of the attack and explain how security objectives (CIA triad, etc.) were compromised.	15%
Business Impact & Assets Compromised	Analyze the business or organizational impact, and specify the assets targeted and/or compromised.	10%
CWE(s) Associated with the CVE	Identify and explain the CWE(s) that are linked to the CVE, providing context on the underlying vulnerabilities.	10%
Attack Methodology & Prevention Strategies	Describe how the attack was executed and provide feasible prevention or mitigation strategies to avoid recurrence.	15%
Contextual Background	Introduce the company/organization involved, the software under attack, its purpose, and its role in the ecosystem.	10%
Presentation Quality	Evaluate the clarity, structure, and professionalism of the presentation. Include visuals, storytelling, and pacing.	10%
Peer Review Feedback	Assess based on constructive feedback from peers on clarity, engagement, and overall understanding.	10%
Q&A Engagement	Judge the presenter's ability to answer questions and engage with the audience effectively during Q&A.	5%

Presentation Rubric
Peer Review Feedback

Presentation Peer Review Ballot | Total: ___ / 10		
Clarity of Explanation (4 points)	Engagement & Audience Interaction (3 points)	Relevance & Context (3 points)

CVE Archive/Hub



CVE-2024-24377

An official website of the United States government Here's how you know

NIST

NVD MENU

Information Technology Laboratory

NATIONAL VULNERABILITY DATABASE

NIST NATIONAL VULNERABILITY DATABASE NVD

VULNERABILITIES

CVE-2024-24377 Detail

Description

An issue in idocv v.14.1.3_20231228 allows a remote attacker to execute arbitrary code and obtain sensitive information via a crafted script.

Metrics

CVSS Version 4.0 | CVSS Version 3.x | CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

NIST: NVD	**Base Score:** 9.8 CRITICAL	**Vector:** CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
ADP: CISA-ADP	**Base Score:** 8.1 HIGH	**Vector:** CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

QUICK INFO

CVE Dictionary Entry: CVE-2024-24377
NVD Published Date: 02/16/2024
NVD Last Modified: 01/13/2025
Source: MITRE

References to Advisories, Solutions, and Tools

By selecting these links, you will be leaving NIST webspace. We have provided these links to other web sites because they may have information that would be of interest to you. No inferences should be drawn on account of other sites being referenced, or not, from this page. There may be other web sites that are more appropriate for your purpose. NIST does not necessarily endorse the views expressed, or concur with the facts presented on these sites. Further, NIST does not endorse any commercial products that may be mentioned on these sites. Please address comments about this page to nvd@nist.gov.

Hyperlink	Resource
https://zhuabapa.top/2024/01/18/idocv_20231228_rce/#more	Exploit, Third Party Advisory
https://zhuabapa.top/2024/01/18/idocv_20231228_rce/#more	Exploit, Third Party Advisory

Weakness Enumeration

CWE-ID	CWE Name	Source
CWE-77	Improper Neutralization of Special Elements used in a Command ('Command Injection')	NIST, CISA-ADP

Known Affected Software Configurations Switch to CPE 2.2

Configuration 1 (hide)

cpe:2.3:a:idocv:idocview:*:*:*:*:*:*:*:* Show Matching CPE(s)	**Up to (including) 14.1.3_20231228**

Denotes Vulnerable Software

Are we missing a CPE here? Please let us know.

Today's Learning Outcome

1. List different sources of vulnerabilities and unique challenges associated with each
2. Describe the importance of including security in software architecture design
3. Explain the process of vulnerability management in an organization

Vulnerability Sources

Server vulnerabilities

Endpoint vulnerabilities

Supply chain vulnerabilities

Configuration vulnerabilities

Architectural vulnerabilities

Server vulnerabilities

Weaknesses and flaws in web servers or other server-side systems.

- Outdated software / unsupported OS
- Buffer Overflow Vulnerabilities
- Privilege Escalation Threats
- Insecure Protocols (e.g., FTP, Telnet, POP3)
- Servers configured for debugging modes

Endpoint vulnerabilities

Weaknesses associated with individual devices connected to a network.

- Like servers but with stricter configuration
- Common issues:
  - Missing Patches and Outdated Signatures
  - User Reluctance to Update Software

Supply chain vulnerabilities

End-of-Life Alerts: Monitor vendor announcements for product lifecycle changes to prevent security gaps.

Lifecycle Stages: Track end-of-sale, support, and life stages for timely IT product updates.

Embedded & Cloud Risks: Be vigilant of vulnerabilities in embedded systems and the risk transfer in cloud services.

Vendor Oversight: Continuously evaluate vendor reliability and support for cloud and data storage services.

Configuration vulnerabilities

Avoid	default configurations
Verify	device security before network integration
Follow	documented security standards and best practices
Choose	secure cryptographic protocols and strong ciphers
Apply	the principle of least privilege

Architectural **vulnerabilities**

- Incorporate security early in IT system design to prevent fundamental flaws
- Address system sprawl with proper lifecycle management of networked devices
- Go beyond technical aspects to include business processes and human factors

Security Starts at Architecture (Shift-Left)

Decide now which risks are acceptable and which are engineered out.

Architectural patterns
How components are **organized** (risk boundaries)

Software Architecture

Messaging & APIs
Where components **meet** (attack surface)

Constraints
What the system **must** obey (policy & quality attributes)

Shift Left = decide security controls at design time and enforce them in patterns, not just code reviews.

Source: Software Architecture | Architectural patterns | Architecture vs Design pattern

Pick 3 quality attributes for a photo-sharing app and 1 design-time control for each.

Layer/Boundary	Likely Threats (keywords)	Design-time Tactics (keywords)
API Gateway	DoS, auth bypass, IDOR	Rate limit, OAuth2/OIDC, object-level auth, request size caps
Service → DB	SQLi, leakage	Param queries/ORM, least privilege, row-level security, at-rest encryption
Media Storage	Unauthorized access, tampering	Signed URLs, bucket policies, immutability/versioning, server-side encryption
Client → API	XSS, CSRF, replay	Output encoding/CSP, CSRF tokens/same-site, short-lived tokens, TLS/mTLS
Observability	Log tamper, PII leak	Structured audit logs, PII scrubbing, write-once storage, alerting

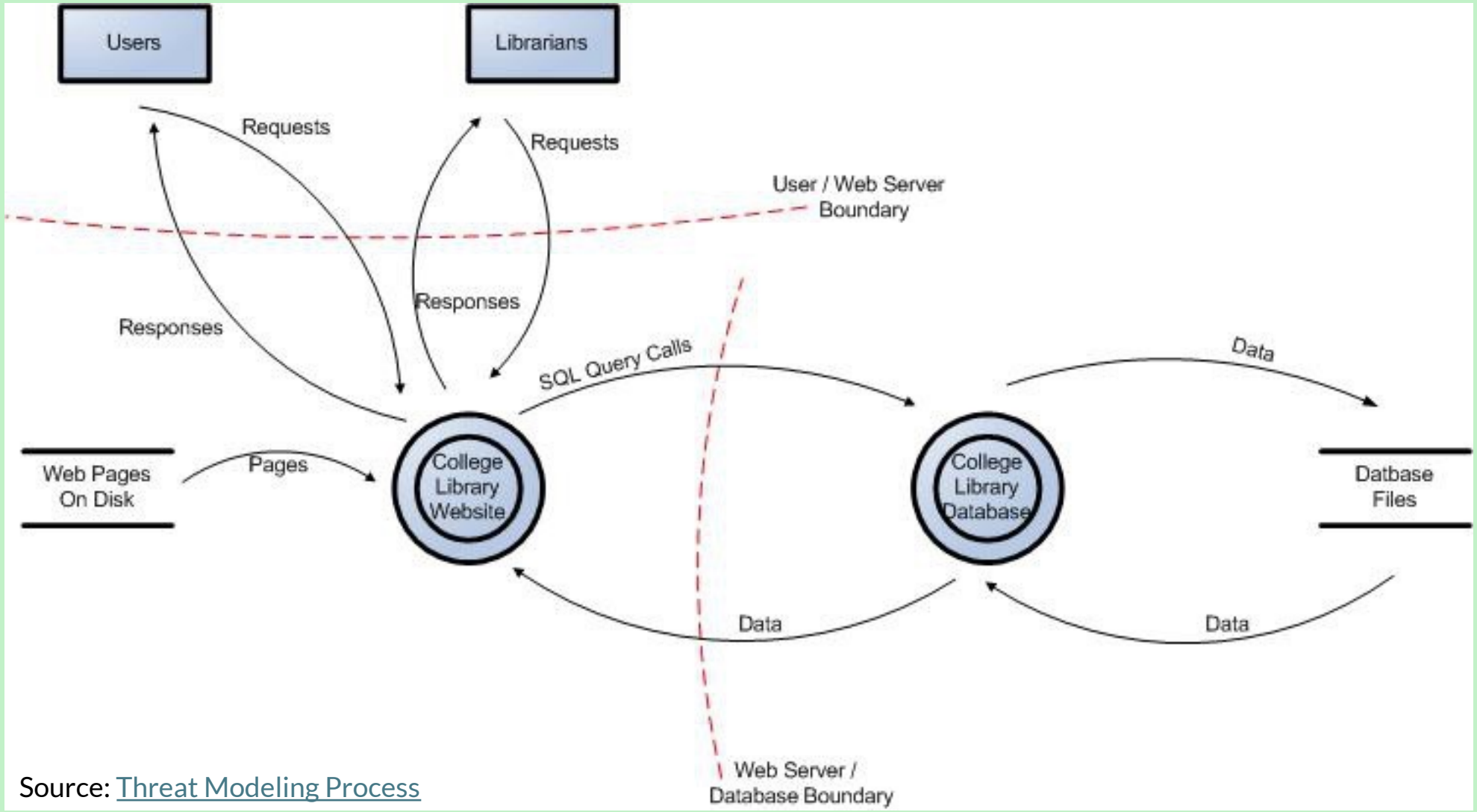
Threat Modeling

- Four questions framework
  - What are we building?
  - What can go wrong? (Be specific)
  - What are we going to do about that?
  - Did we do a good enough job?

S.T.R.I.D.E

Property	Threat	Definition
Authentication	**S**poofing	Impersonating something or someone else.
Integrity	**T**ampering	Modifying data or code
Non-repudiation	**R**epudiation	Claiming to have not performed an action.
Confidentiality	**I**nformation Disclosure	Exposing information to someone not authorized to see it
Availability	**D**enial of Service	Deny or degrade service to users
Authorization	**E**levation of Privilege	Gain capabilities without proper authorization

Data Flow Diagram



Source: [Threat Modeling Process]

Vulnerability Management

Discover

Current-State Analysis

Prioritize

Roadmap for Program Execution

Validate

Measured Progress compared to Current State Analysis

Remediate

Program **Execution**

- Post Assessment Remediation
- Continuous Remediation
- Dedicated Remediation

Standards

- Security Content Automation Protocol (SCAP)
- CVE and NVD databases
- Common Vulnerability Scoring System (CVSS)

CVSS v2.0 Ratings	
Low	0.0-3.9
Medium	4.0-6.9
High	7.0-10.0

CVSS v3.0 Ratings	
Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9
Critical	9.0-10.0

Video: SCAP
Video: CVSS

CVSS v4.0

Base Metric Group

Exploitability Metrics

- Attack Vector
- Attack Complexity
- Attack Requirements
- Privileges Required
- User Interaction

Impact Metrics

- Vulnerable System Confidentiality
- Vulnerable System Integrity
- Vulnerable System Availability
- Subsequent System Confidentiality
- Subsequent System Integrity
- Subsequent System Availability

Scope

Threat Metric Group

*old name: Temporal Metric Group

- Exploit Maturity
- Remediation Level
- Report Confidence

Environmental Metric Group

Modified Base Metrics

- Attack Vector
- Attack Complexity
- Attack Requirements
- Privileges Required
- User interaction
- Vulnerable System Confidentiality
- Vulnerable System Integrity
- Vulnerable System Availability
- Subsequent System Confidentiality
- Subsequent System Integrity
- Subsequent System Availability

- Confidentiality Requirement
- Integrity Requirement
- Availability Requirement

Supplemental Metric Group

- Automatable
- Recovery
- Safety
- Value Density
- Vulnerability Response Effort
- Provider Urgency

KEY

- Existing Component – No Update
- Existing Component – Updated
- Retired Component
- New Component

LAB TIME

BRITISH COLUMBIA
INSTITUTE TECHNOLOGY

BCIT™